

CBK Cybersecurity Guidelines in 2026: Reading the New Regulatory Stack

How the 2017 and 2019 guidelines, the 2024 critical infrastructure regulations, and a new national cyber agency now fit together

A Digital Asset Defenders Deep-Dive Guide | Updated August 2026

Introduction

Kenyan banks and payment service providers no longer answer to a single cybersecurity guideline — they sit inside a stack of overlapping regimes that has grown substantially since 2024. The Central Bank of Kenya (CBK) is actively harmonising its Commercial Banks Cybersecurity Guidelines (2017) and Guidelines on Cybersecurity for Payment Service Providers (2019) with the Computer Misuse and Cybercrimes (Critical Information Infrastructure and Cybersecurity) Regulations, 2024 — and, as of mid-2026, a new national cybersecurity agency has entered the picture as well. This guide interprets what that stack means in practice and how to build a compliance programme that actually holds up against it.

The Regulatory Stack, Piece by Piece

Instrument	What it covers
Commercial Banks Cybersecurity Guidelines, 2017	Baseline risk-based cybersecurity framework for licensed banks: governance, incident reporting, independent testing
Guidelines on Cybersecurity for Payment Service Providers, 2019	Equivalent framework for PSPs, tied explicitly to the National Payment System Act 2011
Computer Misuse and Cybercrimes (Critical Information Infrastructure and Cybersecurity) Regulations, 2024	Designates critical information infrastructure (banks included), sets breach-notification and audit powers, establishes sector-level Cyber Security Operations Centres
National Cybersecurity Agency gazette order, July 2026	Creates an 11-member national board with authority over critical infrastructure across sectors, overlapping existing regulator mandates

CBK's own communications describe this explicitly as harmonisation in progress: the 2017 and 2019 guidelines are being aligned with the 2024 regulations rather than replaced outright, which means banks and PSPs should expect obligations from both layers to apply simultaneously rather than the newer instrument superseding the older ones.

New Institutions You Now Answer To

The Banking Sector Cybersecurity Operations Centre (BS-SOC)

The BS-SOC is a strategic initiative under the CBK Strategic Plan 2024–2027 and a direct implementation of the 2024 critical infrastructure regulations. Sitting under CBK's Cyber Fusion Unit, it provides cyber threat intelligence, incident response, digital forensics, and cyber investigation capability for the banking sector. For regulated institutions, this means CBK now has an operational, technical counterpart — not just a policy office — that can be engaged during a live incident.

A national layer above CBK

In July 2026, a presidential gazette order established an 11-member security-intelligence-finance board with authority over critical infrastructure nationally, positioned as the most structurally ambitious cyber governance move in East Africa to date. The Order's budget, timeline, and jurisdictional boundaries remain unspecified, and its mandate visibly overlaps with existing bodies — the Communications Authority, CBK, and the Data Protection Commissioner among them. For banks and PSPs, the practical implication is straightforward even while the institutional detail is still settling: expect coordinated, possibly duplicated, reporting and audit obligations across regulators for the foreseeable future, and design your compliance programme to produce evidence once and satisfy multiple regulators from the same records, rather than building parallel processes for each.

The Threat Backdrop Driving All of This

The urgency behind this regulatory build-out is visible in the Communications Authority's own quarterly numbers, which have been extraordinarily volatile through the 2025–2026 financial year:

Quarter	Cyber threat events detected (KE-CIRT/CC)	Change
Jan–Mar 2025	2.5 billion	+201.7% on prior quarter
Apr–Jun 2025	4.5–4.6 billion	+80.8%
Jul–Sep 2025	842.3 million	–81.6%
Oct–Dec 2025	4.56 billion	+441%

The Communications Authority attributes part of the swings to genuinely improved detection capability rather than attack volume alone, but the underlying drivers are consistent quarter to quarter: system vulnerabilities from weak patching and misconfiguration account for the large majority of events, DDoS attacks have repeatedly surged (up over eleven-fold in the October–December 2025 quarter alone), and regulators are pointing to the same set of countermeasures every time — offline backups, network segmentation, multi-factor authentication, and zero-trust architecture. The healthcare sector saw a 95% jump in ransomware incidents in one recent reporting month; manufacturing and finance were also called out as rising targets.

Core CBK Cybersecurity Requirements

- **Risk-based information security framework** — documented policy, risk assessment methodology, business continuity plan, and incident response plan.
- **Vulnerability and patch management** — regular vulnerability scanning, risk-based prioritisation, and emergency patch deployment within 24–48 hours for critical findings.
- **Formal change management** — all patches and fixes must go through a documented change control process, not ad hoc deployment.
- **Third-party risk management** — vendors and service providers must be held to the same patch and vulnerability management standards as the institution itself.
- **Independent testing** — institutions are expected to commission at least one independent cyber threat assessment per year, alongside regular penetration testing and, for larger institutions, red team exercises.
- **Quarterly incident reporting to CBK** — using CBK's prescribed reporting format, covering the occurrence and handling of cybersecurity incidents during the period.
- **Zero trust direction** — CBK has established a regulatory framework encouraging a move away from perimeter-based security toward continuous verification.
- **Board-level oversight** — the board must receive and act on the findings of independent assessments, not merely receive them for information.

Building a CBK-Compliant Programme

- 1 Maintain a centralised, continuously updated inventory of all IT assets — you cannot patch or segment what you haven't inventoried.
- 2 Deploy automated vulnerability scanning across that inventory, covering missing patches, misconfigurations, and known CVEs.
- 3 Prioritise remediation using a risk-based method such as CVSS combined with exploit-likelihood scoring (EPSS), rather than working through findings in the order a scanner lists them.
- 4 Maintain detailed audit trails for every patch, configuration change, and security action — this is what both CBK and, separately, the ODPC will ask for first in an inquiry.
- 5 Run regular, methodology-driven penetration testing rather than an annual check-box test.
- 6 Commission an independent cyber threat assessment at least annually and route the findings to the board.
- 7 Align your CBK quarterly incident reporting with your DPA 72-hour breach notification workflow — a single incident at a bank or PSP will very often trigger both obligations at once, and building one incident response process that satisfies both timelines avoids duplicated, inconsistent reporting under pressure.
- 8 Extend all of the above to critical third-party vendors through contractual security requirements and periodic assessment.

How Digital Asset Defenders Can Help

- CBK cybersecurity compliance assessments against the harmonised 2017/2019/2024 requirements
- Vulnerability and patch management programme design
- Penetration testing and red team exercises
- Zero trust architecture design and implementation
- Incident response capability development, including a joint CBK/DPA reporting workflow
- Third-party and vendor risk management programmes

The regulatory stack Kenyan financial institutions now operate under is more layered than it was even two years ago, and the threat data explains why regulators keep tightening it. Digital Asset Defenders helps banks, PSPs, and fintechs build a single, evidence-based security programme that satisfies CBK, the ODPC, and whichever national body ultimately takes shape around the 2026 gazette order — rather than juggling separate compliance tracks for each. Contact us to assess where your current programme stands.

Sources & Further Reading

- Central Bank of Kenya, “Establishment of Banking Sector Cyber Security Operations Centre”, press release
- Central Bank of Kenya, Guidance Note on Cybersecurity for the Banking Sector, 2017
- Central Bank of Kenya, Guidelines on Cybersecurity for Payment Service Providers, 2019
- Computer Misuse and Cybercrimes (Critical Information Infrastructure and Cybersecurity) Regulations, 2024
- CyberSpace Chronicles, “Kenya National Cybersecurity Agency Order 2026 Explained”, July 2026
- Communications Authority of Kenya / National KE-CIRT/CC, quarterly Cyber Security Reports, FY2025/26
- The Star, “2025 in review: Kenya’s cybersecurity journey from threats to strategy”
- Capital FM Africa / East African Herald, “Cyber threats surge 441pc to 4.56bn on digital growth”, April 2026
- Xcobeau, “Kenya Cloud & Data Protection Compliance 2026”